

International Information Technology University (IITU)

Кафедра кібербезпеки

Факультет комп'ютерних технологій та кібербезпеки

EGR6301 — Ethical Hacking

ЛАБОРАТОРНА РОБОТА № 4

Пасивна розвідка та просунуте активне сканування

Тиждень	4
Тривалість	90 хвилин
Всього балів	100
Інструменти	Kali Linux, Metasploitable 2, Інтернет (Ч. 1), Браузер (Shodan, crt.sh)
Формат задачі	PDF або DOCX зі скріншотами

⚠ НІКОЛИ не запускайте Nmap, NSE або Nikto проти систем поза лабораторним середовищем. Сканування без авторизації — кримінальний злочин.

Цілі навчання

1. Класифікувати техніки розвідки як пасивні або активні на основі генерації трафіку до цілі, та обґрунтувати класифікацію.
2. Виконати реальні OSINT-запити (WHOIS, DNS, CT Logs, Shodan) до публічного домену та інтерпретувати результати.
3. Порівняти типи сканування SYN, TCP Connect та UDP у Nmap та пояснити, коли кожен доречний.
4. Застосувати OS fingerprinting та оцінити рівень впевненості результату.
5. Виконати цільові NSE-скрипти та розрізнати «strong lead» від «confirmed vulnerability».
6. Запустити Nikto та класифікувати кожну знахідку (вразливість / місконфіг. / інформаційна).
7. Синтезувати пасивні та активні знахідки у збагачену карту з 7 колонками та обґрунтованими ризиками.
8. Оцінити юридичні вимоги до кожної техніки і визначити, які потребують SoW або RoE.

Частина 1 — Концептуальні основи (25 балів)

Ця частина не потребує терміналу. Відповідайте письмово, показуючи логіку.

Завдання 1.1 — Класифікація пасивна/активна (10 балів)

Нижче наведено вісім розвідувальних дій. Для кожної класифікуйте її як пасивну або активну. Класифікація має містити обґрунтування одним реченням, яке посилається на генерацію трафіку. Просто написати «пасивна» без обґрунтування = 0 балів.

(a) Google: site:target.com filetype:pdf (b) nmap -sS проти цілі (c) dig target.com MX через 8.8.8.8 (d) dig @ns1.target.com target.com AXFR (e) Shodan: org:"Target Corp" (f) Nikto проти http://target:80 (g) crt.sh: %.target.com (h) nmap --script smb-vuln-ms17-010 -p 445 target

Завдання 1.2 — Аналіз DNS-записів (8 балів)

Пентестер виконав три команди під час OSINT. Для кожної поясніть: який тип DNS-запису, що він розкриває, як це корисно для планування. Покажіть логіку покроково.

```
$ dig target.com A +short      → 93.184.216.34
$ dig target.com MX +short    → 10 aspmx.l.google.com.
$ dig target.com TXT +short   → "v=spf1 include:_spf.google.com ~all"
```

Завдання 1.3 — Методологія OSINT (7 балів)

Клієнт замовив пентест домену example-corp.com. Перед активним скануванням у вас 30 хвилин на пасивну розвідку. Опишіть покроково методологію. Для кожного кроку назвіть інструмент, очікувану інформацію, спосіб документування. Поясніть, чому порядок кроків має значення.

Частина 2 — Практичні завдання в терміналі (40 балів)

Всі скріншоти мають показувати повну команду та вивід. Обрізані скріншоти не приймаються.

Завдання 2.1 — OSINT: реальні запити до scanme.nmap.org (10 балів)

Виконайте чотири OSINT-запити до публічного домену scanme.nmap.org. Для кожного запиту додайте скріншот та інтерпретацію одним реченням.

(a) whois scanme.nmap.org — запишіть реєстранта, NS, термін. (b) dig A/MX/TXT +short — поясніть кожний тип запису. (c) crt.sh: усі субдомени nmap.org. (d) Shodan: порти та банери. Поясніть, чому Shodan може відрізнятися.

Завдання 2.2 — Порівняння Nmap (10 балів)

Запустіть два скани проти Metasploitable 2 на портах 21, 22, 25, 80, 139, 445. Додайте скріншоти. Запишіть час. Коротким абзацом поясніть різницю SYN і TCP Connect на рівні handshake, та чому SYN потребує root.

```
$ sudo nmap -sS -p 21,22,25,80,139,445 192.168.56.101
$ nmap -sT -p 21,22,25,80,139,445 192.168.56.101
```

Завдання 2.3 — UDP та OS Detection (8 балів)

Запустіть UDP-скан топ-20 та визначення ОС. Додайте скріншоти. Визначте UDP-сервіси (особливо SNMP/161). Для OS: запишіть відсоток впевненості, поясніть, чому ймовірісне і що може спотворити.

```
$ sudo nmap -sU --top-ports 20 192.168.56.101
$ sudo nmap -O 192.168.56.101
```

Завдання 2.4 — Цільові NSE (6 балів)

Запустіть три NSE-скрипти. Додайте скріншоти. Для кожного напишіть одне речення: що перевіряв скрипт і що означає результат.

```
$ nmap --script ftp-anon -p 21 192.168.56.101
$ nmap --script smb-vuln-ms17-010 -p 445 192.168.56.101
$ nmap --script http-methods -p 80 192.168.56.101
```

Завдання 2.5 — Nikto (6 балів)

Запустіть Nikto. Додайте скріншот. Класифікуйте кожну знахідку: вразливість, міskonфігурація або інформаційне. Подайте як таблицю: Знахідка, Категорія, Обґрунтування.

```
$ nikto -h http://192.168.56.101
```

Частина 3 — Системне мислення (20 балів)

Відповідайте письмово. Покажіть покрокову логіку.

Сценарій 3.1 — Інтерпретація NSE (7 балів)

Ви запускаєте `nmap --script ftp-vsftpd-backdoor -p 21 192.168.56.101` і отримуєте «VULNERABLE: vsFTPD version 2.3.4 backdoor.» Ваш молодший колега одразу пише у звіт «Confirmed: vsftpd backdoor present.» Поясніть покроково, чому це неправильно. Що означає «VULNERABLE» у NSE? Які додаткові кроки потрібні до «Confirmed»?

Сценарій 3.2 — Вибір типу сканування (6 балів)

Ви плануєте пентест корпоративної мережі з активною IDS. Правила дозволяють сканування, але просять мінімального виявлення. Поясніть логіку вибору між `-sS`, `-sT`, `-sU`. Зважте на stealth, швидкість, root, типи сервісів. Для кожного типу вкажіть: використовуєте чи ні, і чому.

Сценарій 3.3 — Траблшутінг OS Detection (7 балів)

Ви запускаєте `nmap -O` і отримуєте: «No exact OS matches. Too many fingerprints match.» Поясніть покроково, як Nmap виконує OS detection всередині (зонди, аналіз, база). Назвіть щонайменше три причини цієї помилки. Опишіть альтернативні підходи для визначення ОС.

Частина 4 — Безпека та аудит (15 балів)

Завдання 4.1 — Збагачена карта сервісів (10 балів)

Об'єднайте все, що зібрали в Частинах 1–3, у збагачену карту з 7 колонками: Порт, Сервіс, Версія, ОС, OSINT, NSE/Nikto, Ризик. Щонайменше 5 сервісів. У колонці NSE/Nikto підсумуйте своїми словами. Обґрунтуйте кожен ризик.

Під картою напишіть абзац з трьома найперспективнішими векторами атаки. Поясніть: наявність експлойтів, pre/post-auth, CVSS.

Завдання 4.2 — Юридична класифікація (5 балів)

Для кожної з семи технік вкажіть: не потребує спеціальної авторизації (low-risk, scope), SoW, або SoW + RoE. Обґрунтуйте кожен одним реченням: Google dorking, WHOIS, DNS public, Nmap, Nikto, NSE vuln, DNS AXFR.

Критерії оцінювання

Частина	Бали	Критерії
Ч. 1: Концептуальна	25	Класифікація (10) + DNS-аналіз (8) + методологія OSINT (7)
Ч. 2: Практична	40	OSINT + інтерпр. (10) + Nmap порівн. (10) + UDP/OS (8) + NSE (6) + Nikto табл. (6)
Ч. 3: Системне	20	NSE логіка (7) + вибір скану (6) + OS траблшутінг (7)
Ч. 4: Безпека	15	Збаг. карта + топ-3 (10) + юрид. класиф. (5)
ВСЬОГО	100	Правильність, покрокова логіка, скріншоти, безпекова обізнаність

Інструкції до задачі

Здайте один файл PDF або DOCX. Ім'я файлу: Lab4_EGR6301_Прізвище_Ім'я.pdf. Файл має містити всі чотири частини, кожна з нової сторінки. Додайте скріншоти для кожної команди

(Частина 2). Письмові відповіді мають демонструвати розуміння. Збагачена карта (4.1) — найважливіший deliverable. Здайте до дедлайну.